

Application Access and Account Security Policy

Identity verification, least privilege, access requests, MFA, and incident handling

Document ID	NDS-SEC-POL-008
Version	1.0
Owner	IT Service Operations
Classification	Internal — Fictional training content
Effective date	1 October 2026
Review cycle	Every 12 months or after a major service change

Important: Northstar Digital Services is a fictional company created solely for RAG, document retrieval, citation, and corporate AI training exercises. These procedures are illustrative and are not instructions for any real organization.

1. Policy statement

Northstar Digital Services (NDS) grants access to corporate applications and data based on verified identity, approved business need, and the principle of least privilege. This fictional policy describes training examples for identity and access management. It does not replace any real employer's security policy or legal obligations.

2. Core principles

- **Unique identity:** each user must use their own named account; shared accounts are prohibited unless an approved technical exception exists.
- **Least privilege:** grant only the permissions required for the user's role and current responsibilities.
- **Separation of duties:** sensitive actions may require a separate approver or a second person.
- **Time-bound access:** temporary access should have an expiry date and be removed when no longer required.
- **Traceability:** access requests, approvals, grants, and removals must be recorded in the approved workflow.
- **Periodic review:** application owners must review access at the defined interval and remove unnecessary permissions.

3. Requesting application access

Step 1 — Identify the exact resource

Specify the application, environment (development, test, or production), role or permission set, and the business task requiring access.

Step 2 — Submit a service request

Use the approved service portal. Include a concise business justification, required start date, and end date if access is temporary.

Step 3 — Obtain approval

The line manager confirms business need. The application owner or data owner approves access to the relevant system or information. Sensitive or privileged access may require additional security approval.

Step 4 — Verify identity and eligibility

IT confirms the requester's identity and checks that required training, device compliance, and other prerequisites are satisfied.

Step 5 — Provision access

The designated support or application team grants the approved permission set and records the change. The requester must not provision their own access unless a documented, authorized process explicitly permits it.

Step 6 — Confirm and review

The requester verifies access. The ticket records the completion time, approvers, assigned role, and expiry/review date.

4. Approval matrix (illustrative)

Resource type	Required approval	Additional control
Standard collaboration app	Line manager or delegated approver	Corporate identity and MFA

Resource type	Required approval	Additional control
Customer/project workspace	Line manager plus project/data owner where required	Membership restricted to the assigned project
Sensitive business data	Data owner and relevant manager	Data classification and access logging
Production system	System owner and designated change/security approver	Separate privileged access; audit trail
Administrator role	System owner plus security approval	Time-bound elevation and stronger monitoring
Emergency access	Incident commander or authorized emergency approver	Document reason, duration, actions and retrospective review

5. Multi-factor authentication and account protection

- Use only the approved MFA methods registered to your identity.
- Approve a sign-in prompt only when you initiated the sign-in and the displayed context is expected.
- Deny and report unexpected or repeated prompts; treat them as a possible account-compromise indicator.
- Never disclose passwords, one-time codes, recovery codes, private keys, or session tokens to anyone.
- Use the approved password manager if provided. Do not reuse corporate passwords on personal websites.
- If credentials may have been exposed, report the event immediately and follow the security team's instructions for account containment and credential reset.

6. Joiner, mover, and leaver lifecycle

Joiner — Access is provisioned after identity verification and role confirmation. Managers request only the applications needed for the person's initial duties.

Mover — When an employee changes team or role, the manager requests new access and identifies permissions to remove. Old access should not remain merely because it was previously granted.

Leaver — HR or the authorized manager triggers the offboarding workflow. Access is disabled according to the approved timeline, sessions/tokens are handled through standard controls, and company assets are returned. Sensitive cases may require immediate coordinated action.

7. Access review and recertification

- Application owners review membership and permission assignments on the schedule defined for the application's risk level.
- Reviewers should confirm each user's current role, business need, permission scope, and access expiry.
- Unconfirmed or unnecessary access should be removed through a tracked change, not merely noted in a spreadsheet.
- Exceptions must identify the business reason, approving owner, compensating controls, expiry date, and review date.

8. Suspected account compromise

- Report suspected compromise through the security incident channel immediately.

- Include the account, approximate time, suspicious activity, affected device, and any relevant alert or message.
- Do not delete suspicious messages or logs unless instructed; preserve evidence according to the incident team's direction.
- Do not investigate by attempting to access another person's account or by forwarding sensitive data to an unapproved destination.
- The security team coordinates containment, session revocation, credential reset, impact assessment, and recovery.

9. Frequently asked questions

My manager said yes in chat. Is that enough?

Not necessarily. Use the approved access-request workflow so the approval and granted permissions are recorded.

Can I borrow a colleague's account while waiting?

No. Shared credentials remove accountability and may violate access controls. Request temporary access through the approved process.

How do I get administrator access?

Submit a justified request through the privileged-access workflow. It may require additional approval, time limits, and monitoring.

I changed projects. Do I keep my previous access?

Only if there is still a documented business need. Your manager and application owners should review and remove access that is no longer required.

What should I do after an unexpected MFA prompt?

Deny it, report it immediately, and follow security-team instructions. Do not approve it to make the prompts stop.

10. Audit evidence

- Service request and business justification
- Approver identities and timestamps
- Provisioned role/permissions and target resource
- Provisioning/removal timestamps
- Expiry and recertification outcome
- Approved exception record where applicable